

LAPORAN FINAL
CLOUD SECURITY ARSITECTURE

**Perancangan Arsitektur Cloud Security Berbasis Zero Trust dan Integrasi
Blockchain untuk Keabsahan Ijazah serta Transkrip Nilai pada Sistem
Informasi Administrasi SMK**



DISUSUN OLEH :

NAMA : NUR ALIYAH AMALIANI

NIM : 105841106923

KELAS : 6 JK-A

PROGRAM STUDI INFORMATIKA
FAKULTAS TEKNIK
UNIVERSITAS MUHAMMADIYAH MAKASSAR

2026

KATA PENGANTAR

Puji syukur ke hadirat Tuhan Yang Maha Esa atas rahmat dan karunia-Nya sehingga penulis dapat menyelesaikan laporan final Cloud Security Architecture pada sistem My-School. Laporan ini disusun sebagai dokumentasi perancangan, implementasi, dan pengujian keamanan aplikasi administrasi SMK dengan pendekatan Zero Trust serta integrasi blockchain untuk menjaga integritas dokumen akademik.

Penyusunan laporan ini mengacu pada struktur tugas final mata kuliah Cloud Security Architecture. Implementasi yang dibahas meliputi Role-Based Access Control (RBAC), Multi-Factor Authentication (MFA), TLS/HTTPS, Web Application Firewall (WAF) ModSecurity dengan OWASP Core Rule Set, segmentasi jaringan Docker, HashiCorp Vault untuk secret management pada prototype lokal, enkripsi AES-256-GCM untuk secret MFA, blockchain Ganache, smart contract DocumentRegistry, audit perubahan nilai, digital signature DUDI, serta backup PostgreSQL.

Perlu ditegaskan bahwa sistem yang diuji pada laporan ini merupakan prototype lokal berbasis Docker dan Ganache. Komponen AWS/GCP yang disebutkan pada rancangan cloud digunakan sebagai arsitektur target dan pemetaan implementasi, bukan sebagai klaim bahwa sistem telah dideploy pada layanan cloud produksi. Perbedaan tersebut dijelaskan secara eksplisit pada Bab II dan Bab V.

Penulis menyadari bahwa laporan dan implementasi yang dibuat masih dapat dikembangkan lebih lanjut. Kritik dan saran sangat diharapkan sebagai bahan perbaikan, terutama untuk penerapan pada lingkungan cloud produksi, penggunaan KMS/HSM sebenarnya, monitoring terpusat, dan pengujian keamanan yang lebih luas.

Makassar, Agustus 2026

Penulis

DAFTAR ISI

KATA PENGANTAR	2
DAFTAR ISI.....	3
BAB I PENDAHULUAN	4
1.1 Latar belakang	4
1.2 Rumusan Masalah.....	5
1.3 Tujuan.....	5
1.4 Batasan Sistem.....	6
BAB II PERANCANGAN ARSITEKTUR CLOUD SECURITY	7
2.1 Diagram topologi network cloud (VPC, Subnet, Gateway).....	7
2.2 Penerapan Zero Trust Model Dan Identity Access Management (IAM).....	10
2.3 Strategi Enkripsi (In-Transit, At-Rest) dan Backup/Disaster Recovery	12
BAB III INTEGRASI BLOCKCHAIN DAN SMART CONTRACT	15
3.1 Arsitektur Jaringan Blockchain (Private / Consortium).....	15
3.2 Rancangan Smart Contract (Solidiity / chaincode).....	16
3.3 Mekanisme Verifikasi dokumen administrasi.....	16
BAB IV PENGUJIAN DAN ANALISIS KEAMANAN.....	19
4.1 Hasil Pengujian Keamanan Web Dan Cloud (Penetration Testing)	19
4.2 Hasil Audit Smart Contract dan Pengujian Integritas Dokumen	28
BAB V KESIMPULAN DAN REKOMENDASI	35
5.1 Kesimpulan.....	35
5.2 Saran	36

BAB I

PENDAHULUAN

1.1 Latar belakang

Digitalisasi administrasi sekolah membuat pengelolaan data siswa, guru, nilai, transkrip, ijazah, dan sertifikat semakin bergantung pada aplikasi berbasis web. Kondisi ini memberikan kemudahan pada proses administrasi, tetapi juga meningkatkan risiko apabila autentikasi, otorisasi, jaringan, database, dan dokumen digital tidak dilindungi secara memadai.

Pada sistem administrasi sekolah, ancaman tidak hanya berasal dari pihak luar. Perubahan nilai tanpa kewenangan, penyalahgunaan akun administratif, kebocoran token atau private key, serangan terhadap aplikasi web, serta pemalsuan ijazah dan sertifikat juga dapat berasal dari kesalahan konfigurasi maupun penyalahgunaan hak akses internal. Oleh karena itu, keamanan perlu dirancang secara berlapis dan tidak hanya bergantung pada satu mekanisme.

Proyek My-School menggabungkan dua pilar utama. Pilar pertama adalah Cloud Security Architecture dengan prinsip Zero Trust, yaitu setiap akses harus diverifikasi, hak akses dibatasi sesuai kebutuhan, dan komunikasi antarkomponen tidak diberikan kepercayaan secara otomatis. Pilar kedua adalah blockchain untuk pencatatan hash dokumen dan audit data yang membutuhkan integritas tinggi, seperti transkrip, ijazah, sertifikat PKL, dan perubahan nilai.

Implementasi yang tersedia saat ini dijalankan pada lingkungan lokal menggunakan Docker, PostgreSQL, HashiCorp Vault, ModSecurity/OWASP CRS, dan Ganache. Arsitektur tersebut digunakan sebagai prototype untuk memetakan rancangan target multi-tier cloud yang pada lingkungan produksi dapat menggunakan layanan AWS atau GCP. Dengan pendekatan ini, laporan dapat membedakan dengan jelas antara komponen yang sudah diuji pada prototype dan komponen cloud yang masih berupa rancangan target.

1.2 Rumusan Masalah

Berdasarkan latar belakang tersebut, rumusan masalah dalam project ini adalah:

- 1.2.1 Bagaimana membatasi akses pengguna berdasarkan peran Siswa, Guru, Staf TU, Kepala Sekolah, dan Mitra Industri (DUDI)?
- 1.2.2 Bagaimana menerapkan prinsip Zero Trust pada lapisan identitas, aplikasi, jaringan, data, dan secret management?
- 1.2.3 Bagaimana melindungi aplikasi dan API dari request berbahaya seperti SQL Injection, XSS, path traversal, brute-force, dan request berlebihan?
- 1.2.4 Bagaimana menggunakan blockchain untuk menjaga integritas transkrip, document akademik, serta sertifikat PKL, dan audit perubahan nilai?
- 1.2.5 Bagaimana membuktikan mekanisme keamanan tersebut melalui pengujian web, konfigurasi jaringan, smart contract, dan integritas dokumen?

1.3 Tujuan

Berdasarkan rumusan masalah tersebut, tujuan dari project My-School ini adalah:

- 1.3.1 Merancang arsitektur cloud security berlapis dengan pemisahan public, private application, dan isolated data layer.
- 1.3.2 Menerapkan authentication, RBAC, dan MFA untuk akun administratif sebagai control identitas dan akses
- 1.3.3 Menerapkan TLS/HTTPS, WAF, security headers, filtering, rate limiting, segmentasi jaringan, dan secret management.
- 1.3.4 Menerapkan enkripsi AES-256-GCM pada secret MFA serta memastikan file secret tidak ikut ter-track ke repository Git.

- 1.3.5 Mengintegrasikan blockchain Ganache dan smart contract DocumentRegistry untuk registrasi, verifikasi, serta audit integritas data.
- 1.3.6 Melakukan pengujian keamanan menggunakan bukti terminal, Hardhat, Slither, OWASP ZAP, dan skenario manipulasi dokumen.

1.4 Batasan Sistem

Rancangan cloud mengikuti konsep multi-tier AWS/GCP pada instruksi tugas, sedangkan implementasi aktual berupa prototype lokal. Karena itu, AWS/GCP IAM, Cloud KMS/HSM, Shield/Cloud Armor, object storage WORM, CloudTrail/GuardDuty, Prowler, dan Scout Suite belum diuji pada cloud nyata. Padanan lokal yang diuji meliputi RBAC/MFA, ModSecurity OWASP CRS, Docker public/private network, Vault dev mode, TLS lokal, AES-256-GCM pada MFA secret, ZAP, Slither, Hardhat, dan backup PostgreSQL. Sistem tidak ditujukan untuk menyatakan keamanan secara mutlak, tetapi untuk membuktikan bahwa mekanisme keamanan yang diterapkan berjalan sesuai rancangan.

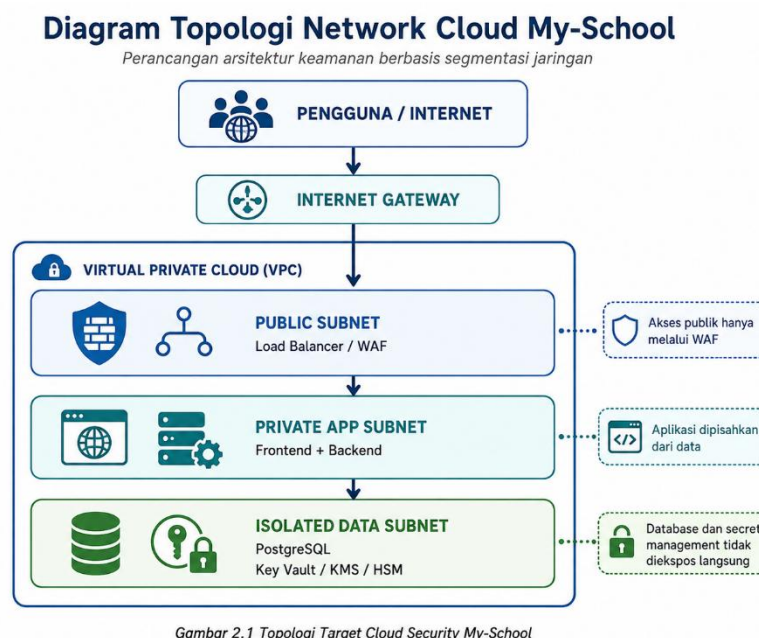
BAB II

PERANCANGAN ARSITEKTUR CLOUD SECURITY

2.1 Diagram topologi network cloud (VPC, Subnet, Gateway)

Perancangan arsitektur keamanan pada sistem My-School menggunakan konsep multi-tier architecture dengan pemisahan antara lapisan yang menerima akses pengguna, lapisan aplikasi, dan lapisan penyimpanan data. Pemisahan tersebut bertujuan agar setiap komponen hanya dapat berkomunikasi dengan komponen lain yang memang diperlukan sehingga akses langsung terhadap database dan penyimpanan secret dapat dibatasi.

Sesuai rancangan pada tugas Cloud Security Architecture, arsitektur target dapat diterapkan pada lingkungan AWS maupun Google Cloud Platform (GCP). Pada arsitektur cloud, jaringan utama dapat ditempatkan di dalam Virtual Private Cloud (VPC) dan dibagi menjadi beberapa subnet sesuai fungsi dan tingkat aksesnya. Instruksi tugas menentukan pemisahan menjadi public subnet untuk komponen yang menerima trafik dari luar, private subnet untuk aplikasi, serta isolated data subnet untuk database dan pengelolaan kunci.



Gambar 2.1 Topologi target cloud security

Pada lapisan pertama terdapat Internet Gateway dan WAF yang menjadi jalur masuk trafik dari pengguna. Web Application Firewall ditempatkan pada

lapisan terluar untuk melakukan pemeriksaan terhadap request sebelum diteruskan ke aplikasi. Pada implementasi cloud menggunakan AWS, fungsi tersebut dapat menggunakan AWS WAF dan AWS Shield, sedangkan pada GCP dapat menggunakan Google Cloud Armor. Rancangan tersebut sesuai dengan kebutuhan tugas yang menempatkan WAF sebagai perlindungan perimeter terhadap ancaman aplikasi web dan trafik yang tidak diinginkan.

Lapisan berikutnya adalah private application subnet yang digunakan untuk menjalankan komponen aplikasi. Frontend dan backend ditempatkan pada lapisan ini agar layanan aplikasi tidak berhubungan langsung dengan database. Backend menjadi komponen yang mengelola proses autentikasi, otorisasi, proses bisnis, komunikasi dengan database, serta komunikasi dengan blockchain.

Lapisan terakhir merupakan isolated data subnet. Lapisan ini digunakan untuk komponen yang memiliki tingkat sensitivitas lebih tinggi, seperti PostgreSQL dan layanan pengelolaan secret atau kunci kriptografi. Dengan rancangan tersebut, database tidak menerima koneksi langsung dari pengguna maupun frontend. Semua akses terhadap data harus melewati backend terlebih dahulu.

Skenario layanan AWS dan GPC sebagai Arsitektur target

Kategori Infrastruktur	Layanan AWS	Layanan GCP
WAF & Edge Security	AWS WAF + AWS Shield	Google Cloud Armor
Identity & Access	AWS IAM + IAM Identity Center	Google Cloud IAM
Compute / Backend	Amazon EKS / AWS Fargate	Google Kubernetes Engine / Cloud Run
Database Operasional	Amazon Aurora PostgreSQL	Cloud SQL for PostgreSQL
Document Storage	Amazon S3 Object Lock / WORM	Cloud Storage Retention Policy
Key Management / HSM	AWS KMS / CloudHSM	Google Cloud KMS
Audit & Monitoring	AWS CloudTrail + GuardDuty	Cloud Audit Logs + Security Command Center

Tabel 2.1 Skenario konfigurasi infrastruktur AWS dan GPC sesuai arsitektur target

Pemetaan rancangan target terhadap prototype local

Kontrol	Target Cloud	Implementasi Prototype	Status
Edge/WAF	AWS WAF + Shield / Cloud Armor	ModSecurity + OWASP CRS 3.3.10	Diimplementasikan lokal; DDoS cloud belum
IAM	AWS/GCP IAM	RBAC aplikasi + MFA	Diimplementasikan pada aplikasi
Network segmentation	Public/Private/Isolated subnet	Docker public_net & private_net	Diimplementasikan lokal
TLS	TLS 1.3 di edge/load balancer	TLS 1.3 pada WAF lokal	Diimplementasikan lokal
Data at rest	AES-256 + KMS/HSM	AES-256-GCM untuk MFA secret	Parsial; belum full-volume encryption
Key management	Cloud KMS/HSM	HashiCorp Vault dev mode	Prototype saja, bukan KMS/HSM produksi
Audit & monitoring	CloudTrail/GuardDuty/SCC	Docker logs + ZAP + Slither	Lokal; cloud monitoring belum

Tabel 2.2 Pemetaan arsitektur target cloud terhadap implementasi local

```

PS D:\My-School> cd D:\My-School
PS D:\My-School> docker compose ps
NAME                IMAGE                COMMAND                SERVICE    CREATED        STATUS        PORTS
smk_backend          my-school-backend   "/docker-entrypoint.s..." backend    38 minutes ago Up 38 minutes 4000/tcp
smk_frontend         my-school-frontend  "/docker-entrypoint.s..." frontend   6 minutes ago  Up 6 minutes  80/tcp, 803/tcp
smk_postgres         postgres:17-alpine  "/docker-entrypoint.s..." postgres   3 days ago     Up 9 hours (healthy) 5432/tcp
smk_vault            hashicorp/vault:2.0.4 /bin/sh -c 'vault s..." vault       2 hours ago    Up 2 hours (healthy) 8200/tcp
smk_waf              owasp/modsecurity-crs:nginx "/docker-entrypoint..." waf        3 minutes ago  Up 3 minutes (healthy) 0.0.0.0:8080->8080/tcp, [::]:8080->8080/tcp, 0.0.0.0:8043->8043/tcp, [::]:8043->8043/tcp
PS D:\My-School>

```

Gambar 2.2 Status container utama setelah implementasi keamanan

```

PS D:\My-School\backend> docker network inspect my-school_public_net | ConvertFrom-Json | ForEach-Object {
>>     $_.Containers.PSObject.Properties.Value.Name
>> }
smk_backend
smk_waf
smk_frontend
PS D:\My-School\backend> docker network inspect my-school_private_net | ConvertFrom-Json | ForEach-Object {
>>     $_.Containers.PSObject.Properties.Value.Name
>> }
smk_backend
smk_postgres
smk_vault
PS D:\My-School\backend> |

```

Gambar 2.3 Hasil inspeksi public_net dan private_net pada Docker

```

PS D:\My-School> docker compose ps
NAME                IMAGE                COMMAND                SERVICE    CREATED        STATUS        PORTS
smk_backend          my-school-backend   "/docker-entrypoint.s..." backend    47 minutes ago Up 47 minutes 4000/tcp
smk_frontend         my-school-frontend  "/docker-entrypoint.s..." frontend   16 seconds ago Up 13 seconds 80/tcp
smk_postgres         postgres:17-alpine  "/docker-entrypoint.s..." postgres   3 days ago     Up About an hour (healthy) 5432/tcp
smk_vault            hashicorp/vault:2.0.4 /bin/sh -c 'vault s..." vault       4 hours ago    Up About an hour (healthy) 8200/tcp
smk_waf              owasp/modsecurity-crs:nginx "/docker-entrypoint..." waf        15 seconds ago Up 12 seconds (health: starting) 0.0.0.0:8080->8080/tcp, [::]:8080->8080/tcp, 0.0.0.0:8043->8043/tcp, [::]:8043->8043/tcp
PS D:\My-School> |

```

Gambar 2.4 PostgreSQL tidak dipublikasikan langsung ke host

```

PS D:\My-School> docker compose ps
NAME                IMAGE                COMMAND                SERVICE    CREATED        STATUS        PORTS
smk_backend          my-school-backend   "/docker-entrypoint.s..." backend    47 minutes ago Up 47 minutes 4000/tcp
smk_frontend         my-school-frontend  "/docker-entrypoint.s..." frontend   16 seconds ago Up 13 seconds 80/tcp
smk_postgres         postgres:17-alpine  "/docker-entrypoint.s..." postgres   3 days ago     Up About an hour (healthy) 5432/tcp
smk_vault            hashicorp/vault:2.0.4 /bin/sh -c 'vault s..." vault       4 hours ago    Up About an hour (healthy) 8200/tcp
smk_waf              owasp/modsecurity-crs:nginx "/docker-entrypoint..." waf        15 seconds ago Up 12 seconds (health: starting) 0.0.0.0:8080->8080/tcp, [::]:8080->8080/tcp, 0.0.0.0:8043->8043/tcp, [::]:8043->8043/tcp
PS D:\My-School> |

```

Gambar 2.5 Frontend tidak lagi dipublikasikan langsung; akses eksternal melalui WAF

2.2 Penerapan Zero Trust Model Dan Identity Access Management (IAM)

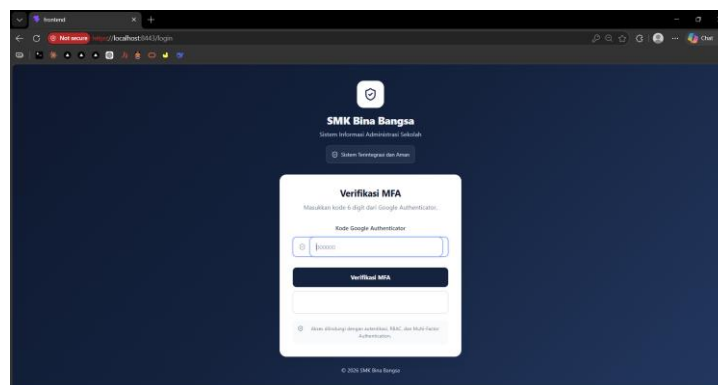
Zero Trust diterapkan dengan prinsip verify explicitly, least privilege, dan assume breach. Identitas pengguna diverifikasi melalui username/password serta MFA pada akun administratif. Setelah autentikasi selesai, backend memeriksa role sebelum mengizinkan operasi sensitif. Dengan demikian, keberhasilan login tidak otomatis memberikan hak untuk mengakses semua endpoint.

Pada prototype lokal, fungsi IAM direpresentasikan oleh authentication, cookie HTTP-only, RBAC backend, dan MFA Google Authenticator. Ini merupakan kontrol identitas pada tingkat aplikasi, bukan implementasi AWS IAM atau Google Cloud IAM. Pada deployment cloud produksi, role aplikasi tetap dipertahankan dan dilengkapi dengan IAM cloud untuk akun operator, service account, dan akses infrastruktur.

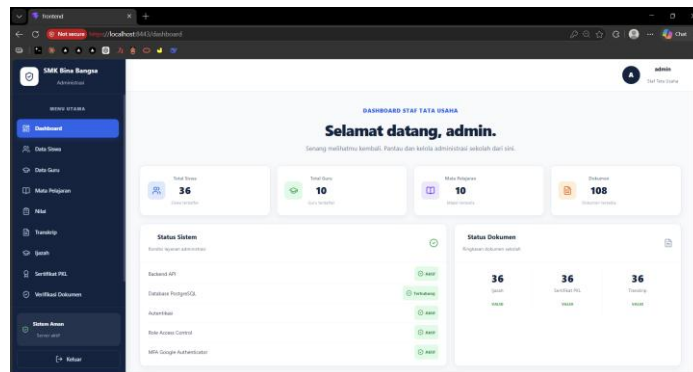
Pembagian peran utama

Role	Hak Akses Utama
SISWA	Melihat data akademik milik sendiri, nilai, transkrip, dan dokumen yang diizinkan.
GURU	Mengelola nilai sesuai penugasan dan melihat data yang berkaitan dengan proses pembelajaran.
STAF_TU	Mengelola data administrasi, transkrip, dokumen, dan operasi administratif yang diizinkan.
KEPALA_SEKOLAH	Melakukan verifikasi/otorisasi fungsi tertentu dan melihat informasi administrasi sesuai kewenangan.
MITRA_INDUSTRI / DUDI	Berinteraksi dengan sertifikat PKL dan fungsi yang memang ditujukan untuk mitra industri.

Tabel 2.3 Pembagian hak akses berbasis role



Gambar 2.6 Halaman verifikasi MFA untuk akun administrative



Gambar 2.7 Dashboard setelah login administratif dan verifikasi MFA berhasil

Pengujian RBAC dilakukan pada endpoint perubahan nilai yang sama. Akun SISWA mendapatkan 403 Forbidden, sedangkan STAF_TU yang telah melewati MFA berhasil menjalankan request dan menerima 200 OK. Perbedaan hasil pada endpoint yang sama menunjukkan bahwa kontrol akses diterapkan pada backend, bukan hanya pada tampilan menu frontend.

```
PS D:\My-School> try {
>> Invoke-WebRequest `
>> -Uri "https://localhost:8443/api/grades/c397484f-c880-4d1d-b866-a5d1f64b94c8" `
>> -Method PUT `
>> -ContentType "application/json" `
>> -Body $bodyNilai `
>> -WebSession $siswa
>> }
>> catch {
>> Write-Host "STATUS:" $_.Exception.Response.StatusCode.value__
>> Write-Host "MESSAGE:" $_.ErrorDetails.Message
>> }
STATUS: 403
MESSAGE: {"success":false,"message":"Kamu tidak memiliki permission untuk melakukan tindakan ini."}
PS D:\My-School>
```

Gambar 2.8 Pengujian RBAC: role SISWA ditolak dengan HTTP 403 Forbidden

```
PS D:\My-School\backend> $bodyNilai = @{
>> finalScore = 91
>> } | ConvertTo-Json
PS D:\My-School\backend> try {
>> $hasil = Invoke-WebRequest `
>> -Uri "https://localhost:8443/api/grades/c397484f-c880-4d1d-b866-a5d1f64b94c8" `
>> -Method PUT `
>> -ContentType "application/json" `
>> -Body $bodyNilai `
>> -WebSession $staf `
>> -UseBasicParsing
>> }
>> Write-Host "STATUS:" $hasil.StatusCode
>> Write-Host "MESSAGE:" $hasil.Content
>> }
>> catch {
>> Write-Host "STATUS:" $_.Exception.Response.StatusCode.value__
>> Write-Host "MESSAGE:" $_.ErrorDetails.Message
>> }
STATUS: 200
MESSAGE: {"success":true,"message":"Nilai berhasil diperbarui dan audit perubahan telah dicatat ke blockchain.", "data":{"grade":{"id":"c397484f-c880-4d1d-b866-a5d1f64b94c8","oldFinalScore":90,"newFinalScore":91,"updatedAt":"2026-08-25T00:17:15.677Z"},"audit":{"auditLogId":"44de1466-440f-4465-a51a-2db7af1a2b96","verificationCode":"GRADE-AUDIT-c397484f-c880-4d1d-b866-a5d1f64b94c8-1787617035310","documentType":"GRADE_AUDIT","hash":"6656f37858e40ed76a359e42a5310af3692854687ff23cd87152fbc94e29107d","transactionHash":"0x7ca574b881a07fab1c9b7030336313a133a080dee8f68bb2e12b071c34a87ce3","changedAt":"2026-08-25T00:17:15.318Z"}}}
PS D:\My-School\backend>
```

Gambar 2.9 Pengujian RBAC: role STAF_TU berhasil dengan HTTP 200 dan audit blockchain

2.3 Strategi Enkripsi (In-Transit, At-Rest) dan Backup/Disaster Recovery

2.3.1 Data in Transit

TLS ditempatkan pada lapisan WAF sebagai edge lokal. Browser mengakses aplikasi melalui <https://localhost:8443>, kemudian WAF meneruskan trafik ke frontend melalui HTTP internal. Konfigurasi mendukung TLS 1.2 dan TLS 1.3, sedangkan sertifikat yang digunakan pada prototype adalah self-signed sehingga browser dapat menampilkan peringatan sertifikat lokal.

```
PS D:\Wy-School> curl.exe -k -I https://localhost:8443
HTTP/1.1 200 OK
Server: nginx
Date: Mon, 24 Aug 2026 22:12:12 GMT
Content-Type: text/html
Content-Length: 658
Connection: keep-alive
Last-Modified: Mon, 24 Aug 2026 22:03:42 GMT
ETag: "6a3cbfbc-ica"
Strict-Transport-Security: max-age=31536000
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera(), microphone(), geolocation(), payment()
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Embedder-Policy: require-corp
Cross-Origin-Resource-Policy: same-origin
Cache-Control: no-store, no-cache, must-revalidate, private
Pragma: no-cache
Content-Security-Policy: default-src 'self'; img-src 'self' data: blob;; style-src 'self' 'unsafe-inline'; script-src 'self'; font-src 'self' data;; connect-src 'self'; object-src 'none'; frame-ancestors 'self'; base-uri 'self'; form-action 'self'
Accept-Ranges: bytes
Access-Control-Allow-Headers: *
```

Gambar 2.10 Pengujian HTTPS/TLS pada endpoint aplikasi

```
PS D:\Wy-School> curl.exe -k --tlsv1.3 -I https://localhost:8443
HTTP/1.1 200 OK
Server: nginx
Date: Mon, 24 Aug 2026 22:12:43 GMT
Content-Type: text/html
Content-Length: 658
Connection: keep-alive
Last-Modified: Mon, 24 Aug 2026 22:03:42 GMT
ETag: "6a3cbfbc-ica"
Strict-Transport-Security: max-age=31536000
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera(), microphone(), geolocation(), payment()
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Embedder-Policy: require-corp
Cross-Origin-Resource-Policy: same-origin
Cache-Control: no-store, no-cache, must-revalidate, private
Pragma: no-cache
Content-Security-Policy: default-src 'self'; img-src 'self' data: blob;; style-src 'self' 'unsafe-inline'; script-src 'self'; font-src 'self' data;; connect-src 'self'; object-src 'none'; frame-ancestors 'self'; base-uri 'self'; form-action 'self'
Accept-Ranges: bytes
Access-Control-Allow-Headers: *
```

Gambar 2.11 Bukti konfigurasi komunikasi HTTPS dan response aplikasi

Selain TLS, response HTTP dilengkapi security headers seperti Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, HSTS, dan beberapa header isolasi browser. Header tersebut berfungsi sebagai lapisan pertahanan tambahan pada sisi browser.

```
PS D:\Wy-School> curl.exe -k -I https://localhost:8443
HTTP/1.1 200 OK
Server: nginx
Date: Mon, 24 Aug 2026 22:13:57 GMT
Content-Type: text/html
Content-Length: 658
Connection: keep-alive
Last-Modified: Mon, 24 Aug 2026 22:03:42 GMT
ETag: "6a3cbfbc-ica"
Strict-Transport-Security: max-age=31536000
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera(), microphone(), geolocation(), payment()
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Embedder-Policy: require-corp
Cross-Origin-Resource-Policy: same-origin
Cache-Control: no-store, no-cache, must-revalidate, private
Pragma: no-cache
Content-Security-Policy: default-src 'self'; img-src 'self' data: blob;; style-src 'self' 'unsafe-inline'; script-src 'self'; font-src 'self' data;; connect-src 'self'; object-src 'none'; frame-ancestors 'self'; base-uri 'self'; form-action 'self'
Accept-Ranges: bytes
Access-Control-Allow-Headers: *
```

Gambar 2.12 Hasil pemeriksaan HTTP security headers

2.3.2 Data at Rest dan Secret Management

Pada prototype, enkripsi AES-256-GCM diterapkan pada MFA secret yang tersimpan di database. Implementasi ini membuktikan bahwa data sensitif tertentu tidak disimpan dalam bentuk plaintext. Namun, enkripsi seluruh volume PostgreSQL belum diterapkan sehingga laporan tidak menyatakan bahwa seluruh database telah terenkripsi AES-256 at rest.

```
PS D:\My-School\backend> docker exec smk_postgres psql `
>> -U postgres `
>> -d smk_administrasi `
>> -c "SELECT mfa_enabled, CASE WHEN mfa_secret LIKE 'enc:v1:%' THEN 'AES-
256-GCM ENCRYPTED' ELSE 'NOT ENCRYPTED' END AS encryption_status FROM users
WHERE mfa_enabled = true;"
 mfa_enabled | encryption_status
-----+-----
t           | AES-256-GCM ENCRYPTED
(1 row)
PS D:\My-School\backend> |
```

*Gambar 2.13 Bukti MFA secret tersimpan dalam format AES-256-GCM
ENCRYPTED*

Secret penting seperti JWT secret, cookie secret, blockchain private key, DUDI signer private key, dan data encryption key dimuat dari HashiCorp Vault pada saat backend dijalankan. Vault yang digunakan adalah dev mode untuk prototype lokal; pada arsitektur produksi kontrol ini perlu diganti atau diperkuat dengan Vault production mode dan/atau Cloud KMS/HSM.

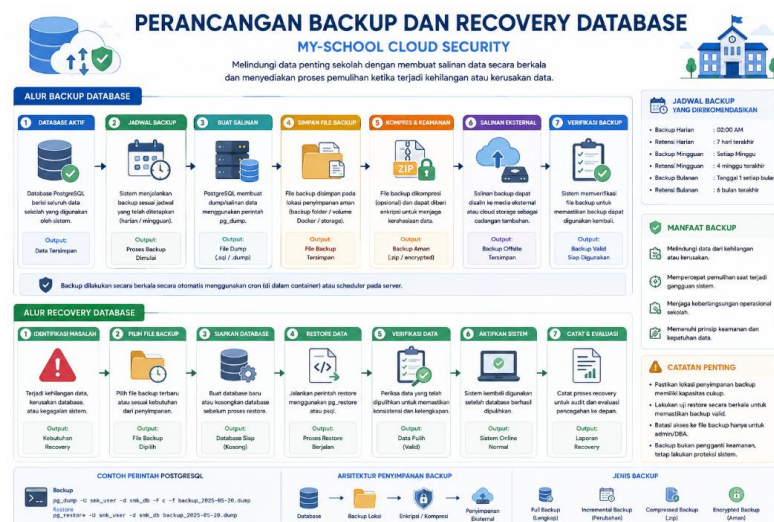
```
tcp          docker logs smk_backend --tail 80
PS D:\My-School>
> backend@1.0.0 start
> tsx src/bootstrap.ts

[VAULT] Secret My-School berhasil dimuat.
[VAULT] 5 secret tersedia untuk backend.
Backend berjalan pada http://localhost:4000
[AUTH] Cookie: ADA
[AUTH] User ID: 8a74c8b9-1b9f-4f3c-8117-61975e066140
[AUTH] Role: STAF_TU
[AUTH] Cookie: ADA
[AUTH] User ID: 8a74c8b9-1b9f-4f3c-8117-61975e066140
[AUTH] Role: STAF_TU
[AUTH] Cookie: ADA
[AUTH] User ID: 8a74c8b9-1b9f-4f3c-8117-61975e066140
[AUTH] Role: STAF_TU
[AUTH] Cookie: ADA
[AUTH] User ID: 8a74c8b9-1b9f-4f3c-8117-61975e066140
[AUTH] Role: STAF_TU
[AUTH] Cookie: ADA
[AUTH] User ID: 8a74c8b9-1b9f-4f3c-8117-61975e066140
[AUTH] Role: STAF_TU
PS D:\My-School>
```

Gambar 2.14 Backend berhasil memuat lima secret dari HashiCorp Vault

2.3.3 Backup dan Disaster recovery

Backup PostgreSQL dibuat menggunakan `pg_dump` dalam format custom dump. File backup disimpan terpisah dari container sehingga dapat digunakan kembali apabila database utama mengalami kerusakan. Untuk membuktikan recovery, backup dapat direstore ke database uji terpisah dan tabel hasil restore diperiksa tanpa mengganggu database utama.



Gambar 2.15 Rancangan proses backup dan recovery database My-School

```
PS D:\My-School\backend\blockchain> Get-ChildItem D:\My-School -Recurse -Include *.sql,*.dump |
>> Select-Object FullName,Length,LastWriteTime

FullName                                                                    Length LastWriteTime
-----
D:\My-School\backend\prisma\migrations\20260818151904_init\migration.sql    4699  8/18/2026 11:19:04 PM
D:\My-School\backend\prisma\migrations\20260818152212_expand_administration_schema\migration.sql 107408  8/18/2026 11:22:12 PM
D:\My-School\backend\prisma\migrations\20260824155743_add_google_authenticator_mfa\migration.sql 129  8/24/2026 11:57:43 PM
D:\My-School\backend\prisma\migrations\20260824180150_add_transcript_blockchain\migration.sql 189  8/25/2026 2:01:50 AM
D:\My-School\backend\prisma\migrations\20260824185325_add_dudi_digital_signature\migration.sql 258  8/25/2026 2:53:25 AM
D:\My-School\smk_backup.dump                                                88496  8/24/2026 10:33:26 PM

PS D:\My-School\backend\blockchain>
```

Gambar 2.16 Bukti file backup PostgreSQL smk_backup.dump berhasil dibuat

```
PS D:\My-School> docker exec smk_postgres psql -U postgres -d smk_restore_test -c '\dt'
```

Schema	Name	Type	Owner
public	_prisma_migrations	table	postgres
public	audit_logs	table	postgres
public	certificates	table	postgres
public	class_members	table	postgres
public	classes	table	postgres
public	diplomas	table	postgres
public	grades	table	postgres
public	graduations	table	postgres
public	students	table	postgres
public	subjects	table	postgres
public	teacher_subjects	table	postgres
public	teachers	table	postgres
public	transcripts	table	postgres
public	users	table	postgres
public	verification_records	table	postgres

(15 rows)

```
PS D:\My-School>
```

Gambar 2.17 Bukti recovery: tabel database muncul pada database hasil restore

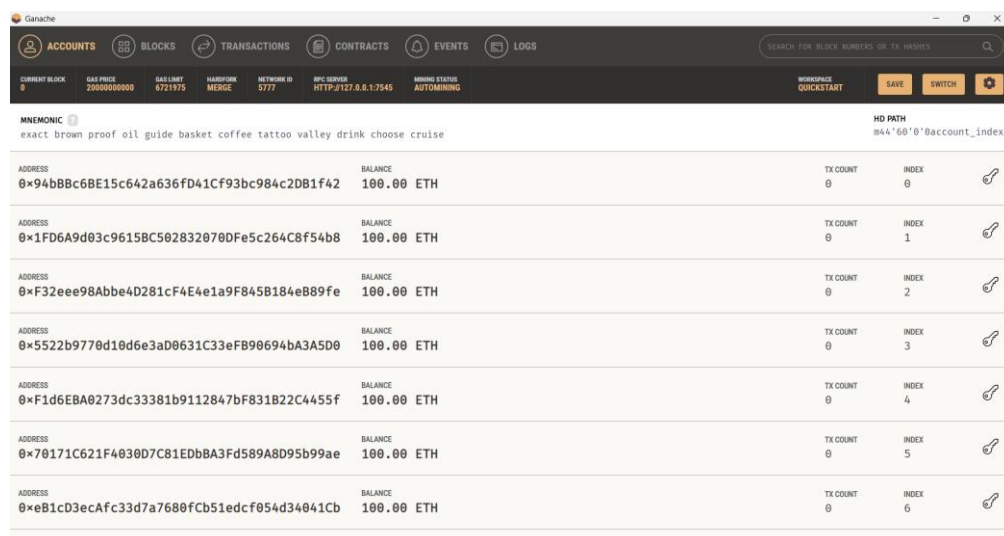
BAB III

INTEGRASI BLOCKCHAIN DAN SMART CONTRACT

3.1 Arsitektur Jaringan Blockchain (Private / Consortium)

Blockchain pada prototype My-School menggunakan Ganache sebagai jaringan Ethereum lokal dengan Chain ID 1337. Jaringan ini bersifat private untuk kebutuhan pengembangan dan pengujian karena hanya dijalankan pada lingkungan lokal. Backend berkomunikasi dengan Ganache melalui JSON-RPC dan menandatangani transaksi menggunakan signer yang secret-nya dikelola di luar source code.

Konsep consortium blockchain pada arsitektur target dapat digunakan ketika sekolah, DUDI, universitas, atau lembaga verifikasi membutuhkan node yang dikelola bersama. Prototype saat ini belum membangun jaringan consortium multi-node; Ganache digunakan untuk membuktikan mekanisme registrasi hash, verifikasi, dan audit transaksi.



Gambar 3.1 Jaringan blockchain lokal Ganache yang digunakan pada prototype

```
PS D:\My-School\backend> docker exec smk_backend node -e "const {ethers}=require('ethers'); const p=new  
rk().then(n=>console.log('BLOCKCHAIN OK - Chain ID:',n.chainId.toString())).catch(console.error)"  
BLOCKCHAIN OK - Chain ID: 1337  
PS D:\My-School\backend> |
```

Gambar 3.2 Pengujian koneksi backend ke blockchain Ganache

3.2 Rancangan Smart Contract (Solidity / chaincode)

Smart contract yang digunakan bernama DocumentRegistry dan ditulis menggunakan Solidity 0.8.28. Contract berfungsi menyimpan metadata minimum yang dibutuhkan untuk integritas dokumen, bukan menyimpan file PDF secara langsung. Data yang dicatat meliputi verification code, document type, document hash, timestamp registrasi, dan status keberadaan data.

Fungsi / Kontrol	Peran
registerDocument()	Mendaftarkan verification code, document type, dan hash dokumen ke blockchain.
verifyDocument()	Membandingkan hash yang diberikan dengan hash yang sudah tercatat.
getDocument()	Mengambil metadata dokumen yang telah diregistrasikan.
onlyOwner	Membatasi registrasi hanya pada signer/owner contract yang berwenang.
Duplicate verification code protection	Menolak verification code yang sudah dipakai.
Duplicate document hash protection	Menolak hash dokumen yang sudah pernah didaftarkan.

Tabel 3.1 Fungsi dan kontrol keamanan DocumentRegistry

Contract tidak menggunakan fungsi payable dan tidak melakukan transfer Ether atau external callback dalam alur registrasi/verifikasi yang diuji. Karena itu, attack surface reentrancy berbasis Ether tidak muncul pada desain saat ini. ReentrancyGuard tidak ditambahkan hanya untuk memenuhi nama kontrol apabila tidak ada alur Ether yang memerlukannya. Pengujian front-running khusus juga belum dilakukan dan menjadi rekomendasi untuk pengembangan berikutnya.

3.3 Mekanisme Verifikasi dokumen administrasi

Proses registrasi dimulai dari file dokumen yang diunggah oleh pengguna berwenang. Backend menghasilkan verification code, menghitung SHA-256, menyiapkan metadata, lalu mengirim data tersebut ke smart contract. File asli

tetap berada di sistem aplikasi; blockchain hanya mencatat nilai yang diperlukan untuk memeriksa integritas.



Gambar 3.3 Alur registrasi dokumen dan hash SHA-256 ke smart contract

Pada saat verifikasi, backend menghitung kembali hash file yang diberikan dan membandingkannya dengan hash di blockchain. Jika sesuai, dokumen dinyatakan valid. Jika file berubah walaupun hanya sedikit, hash akan berbeda dan sistem dapat menandainya sebagai tidak sesuai atau falsified.



Gambar 3.4 Alur proses verifikasi dokumen melalui smart contract

Integrasi blockchain dikembangkan tidak hanya untuk dokumen. Transkrip dapat diregistrasikan dan diverifikasi berdasarkan hash canonical data nilai. Perubahan nilai menghasilkan GRADE_AUDIT yang mencatat verification code, hash audit, transaction hash, serta audit log. Sertifikat PKL juga dilengkapi digital signature DUDI pada prototype untuk menghubungkan integritas file, identitas signer, dan data blockchain.

Data yang dicatat pada ledger menurut fitur

Fitur Administrasi	Peran Blockchain	Data Utama yang Dicatat
Ijazah / Transkrip	Memverifikasi integritas dan keaslian data/dokumen.	SHA-256 hash, verification code/metadata, timestamp, transaction hash.
Sertifikat PKL / Magang	Menghubungkan hash sertifikat dengan signature DUDI.	Hash sertifikat, signature, wallet/signer ID, transaction hash.
Audit Log Nilai	Membuat jejak perubahan nilai yang dapat ditelusuri.	Hash audit, ID terkait, nilai sebelum/sesudah dalam audit aplikasi, transaction hash.

Tabel 3.2 Pemanfaatan blockchain pada fitur administrasi My-School

BAB IV

PENGUJIAN DAN ANALISIS KEAMANAN

4.1 Hasil Pengujian Keamanan Web Dan Cloud (Penetration Testing)

Pengujian dilakukan menggunakan pendekatan gray-box pada lingkungan lokal. Penguji mengetahui arsitektur dan memiliki akun dengan role tertentu, kemudian menguji apakah kontrol akses, WAF, TLS, secret management, network segmentation, dan respons aplikasi bekerja sesuai rancangan. Skenario mengikuti fokus yang ditetapkan pada instruksi tugas, terutama Broken Access Control, parameter manipulation, key/token leakage, dan kontrol perimeter. Gambar 4.1 Tampilan dashboard aplikasi bagian admin

4.1.1 WAF / ModSecurity dan OWASP CRS

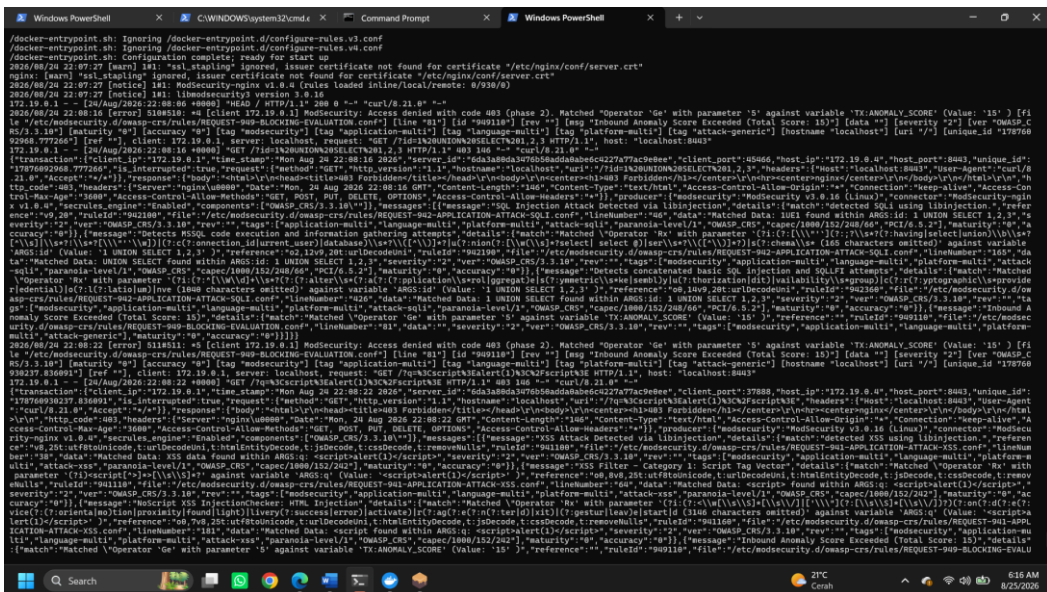
WAF menggunakan image OWASP ModSecurity CRS berbasis Nginx. Log startup menunjukkan aktivasi CRS dan konfigurasi anomaly threshold. WAF menjadi titik masuk ke aplikasi pada port 8080/8443 dan meneruskan request yang lolos ke frontend internal.

```
root@ubuntu:~# docker logs waf-conf -tall 80
/docker-entrypoint.sh /docker-entrypoint.d/ is not empty, will attempt to perform configuration
/docker-entrypoint.sh: Loading shell scripts in /docker-entrypoint.d/
/docker-entrypoint.sh: Launching /docker-entrypoint.d/01-check-for-ports.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/02-generate-certificates.sh
/usr/local/bin/generate-certificates: generating new certificate
Warning: Not adding key to cert as request since request is used
Warning: No copy extensions given: ignoring any extensions in the request
/usr/local/bin/generate-certificates: generate /etc/nginx/conf/server.key and /etc/nginx/conf/server.crt
/docker-entrypoint.sh: Launching /docker-entrypoint.d/10-listen-on-ip-by-default.sh
10-listen-on-ip-by-default.sh: Info: Setting the behaviour of /etc/nginx/conf.d/default.conf
10-listen-on-ip-by-default.sh: Info: /etc/nginx/conf.d/default.conf differs from the packaged version
/docker-entrypoint.sh: Launching /docker-entrypoint.d/30-local-resolvers even
/docker-entrypoint.sh: Launching /docker-entrypoint.d/20-envsubst-on-templates.sh
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/modsecurity.d/modsecurity.conf.template to /etc/nginx/modsecurity.d/modsecurity.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/modsecurity.d/setup.conf.template to /etc/nginx/modsecurity.d/setup.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/includes/core.conf.template to /etc/nginx/includes/core.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/includes/location-common.conf.template to /etc/nginx/includes/location-common.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/includes/proxy-common.conf.template to /etc/nginx/includes/proxy-common.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/includes/proxy_banned_ssl.conf.template to /etc/nginx/includes/proxy_banned_ssl.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/nginx.conf.template to /etc/nginx/nginx.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/conf.d/default.conf.template to /etc/nginx/conf.d/default.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/conf.d/modsecurity.conf.template to /etc/nginx/conf.d/modsecurity.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/conf.d/logging.conf.template to /etc/nginx/conf.d/logging.conf
/docker-entrypoint.sh: Launching /docker-entrypoint.d/20-envsubst-on-templates.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-cpy-modsecurity-conf.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-cpy-modsecurity-conf.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/92-update-real-uid.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/92-update-real-uid.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-activate-plugins.sh
200
Running CRS plugin activation
200
Finished CRS plugin activation
200
```

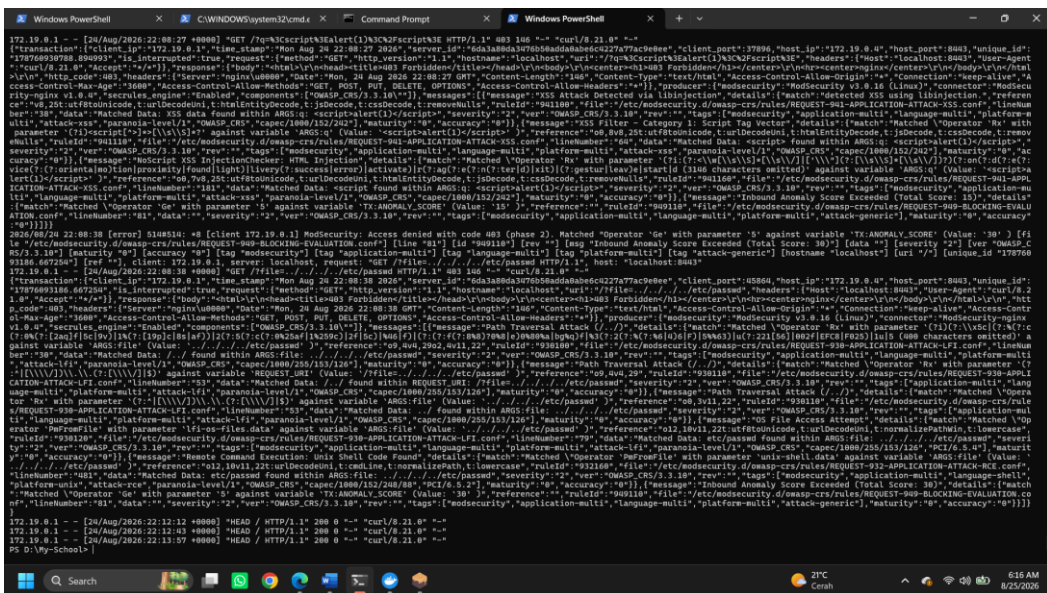
Gambar 4.1 Proses aktivasi ModSecurity/OWASP CRS pada container WAF

```
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-configure-rules.sh
200
Running CRS rule configuration
Selected CRS config file version: 3.1
Configuring rules for RHEL/CentOS with paranoia level=1
Configuring rules for DETECTION/ANALYSIS with exception mechanism level=0
Configuring rules for anomaly detection with limit=anomaly_score_threshold
Configuring rules for anomaly detection with limit=anomaly_score_threshold
Finished CRS rule configuration
200
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-configure-rules.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-configure-rules.sh
/docker-entrypoint.sh: Configuration completed ready for start up
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-configure-rules.sh
/usr/local/bin/generate-certificates: generating new certificate
Warning: Not adding key to cert as request since request is used
Warning: No copy extensions given: ignoring any extensions in the request
/usr/local/bin/generate-certificates: generate /etc/nginx/conf/server.key and /etc/nginx/conf/server.crt
/docker-entrypoint.sh: Launching /docker-entrypoint.d/10-listen-on-ip-by-default.sh
10-listen-on-ip-by-default.sh: Info: Setting the behaviour of /etc/nginx/conf.d/default.conf
10-listen-on-ip-by-default.sh: Info: /etc/nginx/conf.d/default.conf differs from the packaged version
/docker-entrypoint.sh: Launching /docker-entrypoint.d/30-local-resolvers even
/docker-entrypoint.sh: Launching /docker-entrypoint.d/20-envsubst-on-templates.sh
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/modsecurity.d/modsecurity.conf.template to /etc/nginx/modsecurity.d/modsecurity.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/modsecurity.d/setup.conf.template to /etc/nginx/modsecurity.d/setup.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/includes/core.conf.template to /etc/nginx/includes/core.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/includes/location-common.conf.template to /etc/nginx/includes/location-common.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/includes/proxy-common.conf.template to /etc/nginx/includes/proxy-common.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/includes/proxy_banned_ssl.conf.template to /etc/nginx/includes/proxy_banned_ssl.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/nginx.conf.template to /etc/nginx/nginx.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/conf.d/default.conf.template to /etc/nginx/conf.d/default.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/conf.d/modsecurity.conf.template to /etc/nginx/conf.d/modsecurity.conf
20-envsubst-on-templates.sh: Running envsubst on /etc/nginx/templates/conf.d/logging.conf.template to /etc/nginx/conf.d/logging.conf
/docker-entrypoint.sh: Launching /docker-entrypoint.d/20-envsubst-on-templates.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-cpy-modsecurity-conf.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-cpy-modsecurity-conf.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/92-update-real-uid.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/92-update-real-uid.sh
/docker-entrypoint.sh: Launching /docker-entrypoint.d/90-activate-plugins.sh
200
Running CRS plugin activation
200
Finished CRS plugin activation
200
```

Gambar 4.2 Log WAF menunjukkan CRS aktif dan deteksi serangan SQL Injection



Gambar 4.3 Log WAF menunjukkan deteksi SQL Injection dan XSS



Gambar 4.4 Log WAF menunjukkan deteksi XSS dan path traversal

4.1.2 Pengujian SQL Injection

Payload SQL Injection dikirim melalui query parameter. Hasil pengujian menghasilkan HTTP 403 Forbidden. Log WAF menunjukkan rule SQLi OWASP CRS, termasuk deteksi berbasis libinjection dan anomaly score yang melewati threshold pemblokiran.


```
PS D:\My-School> curl.exe -k -i "https://localhost:8443/?id=1%20UNION%20SELECT%201,2,3"
HTTP/1.1 403 Forbidden
Server: nginx
Date: Mon, 24 Aug 2026 22:17:51 GMT
Content-Type: text/html
Content-Length: 146
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Max-Age: 3600
Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
Access-Control-Allow-Headers: *

<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
PS D:\My-School>
```

Gambar 4.5 Response HTTP 403 pada pengujian SQL Injection

[illegible]

Gambar 4.6 Log ModSecurity saat payload SQL Injection diblokir

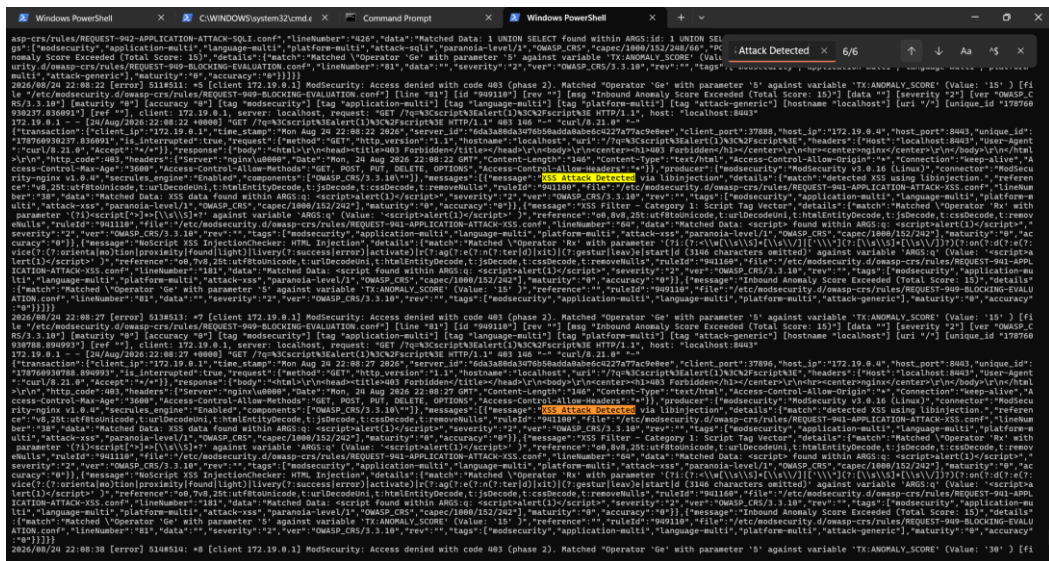
4.1.3 Pengujian Cross-Site Scripting (XSS)

Payload XSS berupa script tag dikirimkan melalui request. WAF menolak request dengan HTTP 403 Forbidden. Log ModSecurity memperlihatkan rule kategori attack-xss yang terpicu dan anomaly score memenuhi kondisi blocking.

```
PS D:\My-School> curl.exe -k -i "https://localhost:8443/?q=%3Cscript%3Ealert(1)%3C%2Fscript%3E"
HTTP/1.403 Forbidden
Server: nginx
Date: Mon, 24 Aug 2026 22:21:54 GMT
Content-Type: text/html
Content-Length: 146
Connection: keep-alive
Access-Control-Allow-Origin: *
Access-Control-Max-Age: 3600
Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
Access-Control-Allow-Headers: *

<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<h2><center>nginx</center>
</body>
</html>
PS D:\My-School> |
```

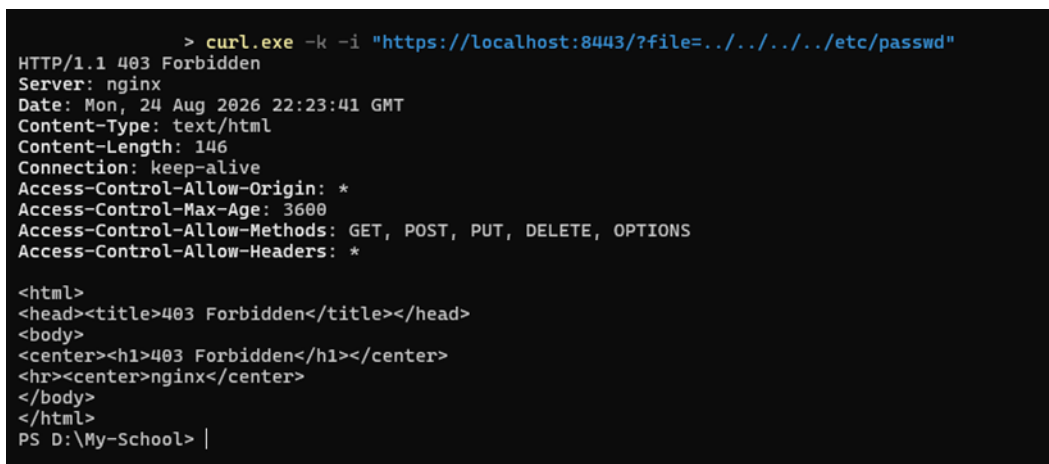
Gambar 4.7 Response HTTP 403 pada pengujian XSS



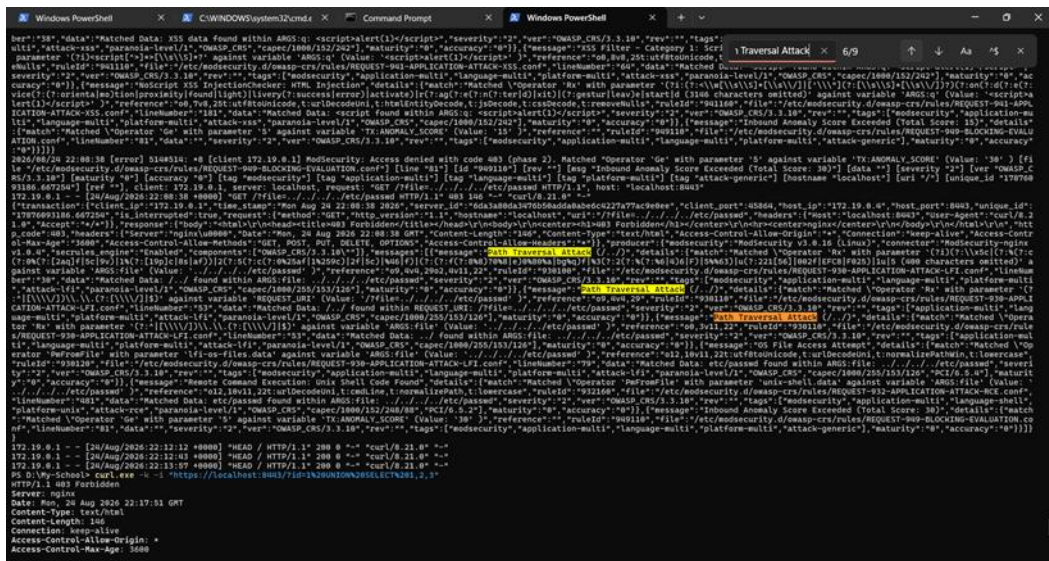
Gambar 4.8 Log ModSecurity saat payload XSS diblokir

4.1.4 Pengujian Path Traversal

Pengujian path traversal dilakukan dengan pola request yang mencoba mengakses path sensitif. WAF mengembalikan HTTP 403 dan log menunjukkan rule LFI/path traversal terpicu. Pengujian ini menunjukkan filtering dilakukan di lapisan perimeter sebelum request diproses aplikasi.



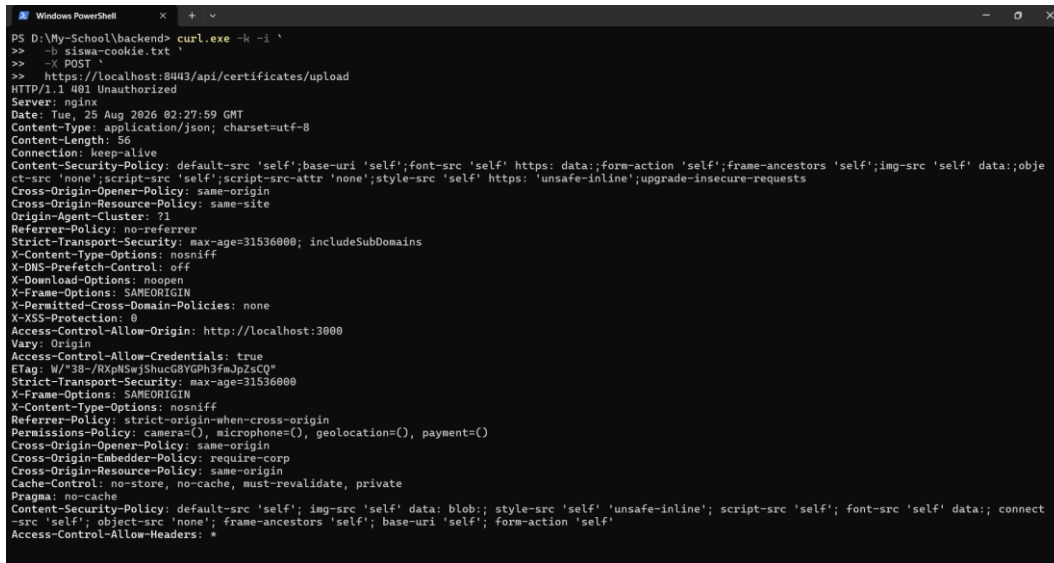
Gambar 4.9 Response HTTP 403 pada pengujian path traversal



Gambar 4.10 Log ModSecurity saat path traversal diblokir

4.1.5 Authentication, RBAC, MFA, dan Rate Limiting

Pengujian Broken Access Control dilakukan untuk memastikan bahwa setiap pengguna hanya dapat menjalankan fungsi sesuai dengan role yang dimilikinya. Pada pengujian pertama, akun dengan role SISWA mencoba melakukan perubahan nilai melalui endpoint PUT /api/grades/:gradeId. Sistem menolak request tersebut dan memberikan respons 403 Forbidden, yang menunjukkan bahwa siswa tidak memiliki izin untuk mengubah data nilai.



Gambar 4.11 Pengujian broken access control pada role siswa

```

PS D:\My-School\backend> $bodyNilai = @{
>>   finalScore = 91
>> } | ConvertTo-Json
PS D:\My-School\backend> try {
>>   $hasil = Invoke-WebRequest `
>>     -Uri "https://localhost:8443/api/grades/c397484f-c880-4d1d-b866-a5d1f64b94c8" `
>>     -Method PUT `
>>     -ContentType "application/json" `
>>     -Body $bodyNilai `
>>     -WebSession $staf `
>>     -UseBasicParsing
>>
>>   Write-Host "STATUS:" $hasil.StatusCode
>>   Write-Host "MESSAGE:" $hasil.Content
>> }
>> catch {
>>   Write-Host "STATUS:" $_.Exception.Response.StatusCode.value__
>>   Write-Host "MESSAGE:" $_.ErrorDetails.Message
>> }
STATUS: 200
MESSAGE: {"success":true,"message":"Nilai berhasil diperbarui dan audit perubahan telah dicatat ke blockchain.,"data":{"grade":{"id":"c397484f-c880-4d1d-b866-a5d1f64b94c8","oldFinalScore":90,"newFinalScore":91,"updatedAt":"2026-08-25T00:17:15.677Z"},"audit":{"auditLogId":"44de1466-440f-4465-a51a-2db7af1a2b96","verificationCode":"GRADE-AUDIT-c397484f-c880-4d1d-b866-a5d1f64b94c8-1787617035318","documentType":"GRADE_AUDIT","hash":"6656f37858e40ed26a359e42a5310af3692854687ff23c487152fbc94e29107d","transactionHash":"0x7ca574b081a97fab1c9b7030336313a133a080dee8f68bb2e12b071c34a87ce3","changedAt":"2026-08-25T00:17:15.318Z"}}}
PS D:\My-School\backend> |

```

Gambar 2.12 pengujian hak akses staf0tu pada perubahan

Akun dengan role STAF_TU yang telah berhasil melakukan autentikasi dan verifikasi MFA melakukan perubahan nilai melalui endpoint PUT. Sistem memberikan respons 200 OK dan mencatat perubahan nilai ke dalam audit blockchain, yang menunjukkan bahwa pengguna dengan role yang sesuai dapat menjalankan fungsi tersebut.

Rate limiting diuji dengan mengirim request berulang. Setelah batas tertentu dilewati, server menghasilkan HTTP 429 Too Many Requests. Pada arsitektur cloud produksi, kontrol ini perlu dilengkapi dengan layanan DDoS protection seperti AWS Shield atau mekanisme yang setara pada GCP.

[illegible]

Gambar 2.13 Pengujian rate limiting dengan respons 429 Too Many Requests

4.1.6 Key Dan Token Leakage / Git Secret Gygiene

Pemeriksaan repository memastikan file secret berada dalam .gitignore dan tidak ter-track oleh Git. File yang diperiksa meliputi .env.docker, token Vault, JWT secret, cookie secret, blockchain private key, DUDI signer private key, dan data encryption key. Hasil git ls-files hanya menampilkan .env.example sebagai template. Pendekatan ini mengurangi risiko secret ikut terpublikasi melalui repository.

```
Windows PowerShell
smk_waf      owasp/modsecurity-crs:nginx   "/docker-entrypoint..." waf      15 seconds ago   Up 12 seconds (health: starting)   0.0.0.0:8080->8080/tcp,
[::]:8080->8080/tcp, 0.0.0.0:8443->8443/tcp, [::]:8443->8443/tcp
PS D:\My-School> git status --short
M .gitignore
M backend/blockchain/contracts/DocumentRegistry.sol
M backend/blockchain/hardhat.config.ts
M backend/package-lock.json
M backend/package.json
M backend/prisma/schema.prisma
M backend/src/config/env.ts
M backend/src/controllers/auth.controller.ts
M backend/src/controllers/certificate.controller.ts
M backend/src/controllers/grade.controller.ts
M backend/src/controllers/transcript.controller.ts
M backend/src/routes/auth.routes.ts
M backend/src/routes/certificate.routes.ts
M backend/src/routes/grade.routes.ts
M backend/src/routes/transcript.routes.ts
M backend/src/validators/auth.validator.ts
M docker-compose.yml
M frontend/Dockerfile
M frontend/nginx.conf
M frontend/src/App.css
M frontend/src/App.tsx
M frontend/src/pages/CertificatePage.tsx
M frontend/src/pages/GradePage.tsx
M frontend/src/pages/TranscriptPage.tsx
M backend/blockchain/slither-report.json
M backend/blockchain/test/SecurityTests.ts
M backend/cek-ganache.cjs
M backend/cek-saldo.cjs
M backend/prisma/migrations/20260824155742_add_google_authenticator_mfa/
M backend/prisma/migrations/20260824180150_add_transcript_blockchain/
M backend/prisma/migrations/20260824185325_add_dudi_digital_signature/
M backend/scripts/
M backend/src/bootstrap.ts
M backend/src/services/dudi-signature.service.ts
M backend/src/services/encryption.service.ts
M backend/src/services/mfa.service.ts
M docker-compose.before-waf.yml
PS D:\My-School> git check-ignore .
```

Gambar 4.14 Status perubahan source code dan file pengujian pada repository

```
Windows PowerShell
M backend/blockchain/test/SecurityTests.ts
M backend/cek-ganache.cjs
M backend/cek-saldo.cjs
M backend/prisma/migrations/20260824155742_add_google_authenticator_mfa/
M backend/prisma/migrations/20260824180150_add_transcript_blockchain/
M backend/prisma/migrations/20260824185325_add_dudi_digital_signature/
M backend/scripts/
M backend/src/bootstrap.ts
M backend/src/services/dudi-signature.service.ts
M backend/src/services/encryption.service.ts
M backend/src/services/mfa.service.ts
M docker-compose.before-waf.yml
PS D:\My-School> git check-ignore .
>> .env.docker
>> secrets/vault_token.txt
>> secrets/jwt_secret.txt
>> secrets/cookie_secret.txt
>> secrets/blockchain_private_key.txt
>> secrets/dudi_signer_private_key.txt
>> secrets/data_encryption_key.txt
.env.docker
secrets/vault_token.txt
secrets/jwt_secret.txt
secrets/cookie_secret.txt
secrets/blockchain_private_key.txt
secrets/dudi_signer_private_key.txt
secrets/data_encryption_key.txt
PS D:\My-School> git ls-files |
>> Select-String .
>> "vault_token|jwt_secret|cookie_secret|blockchain_private_key|dudi_signer_private_key|data_encryption_key|\.env"
.env.example
PS D:\My-School> cd D:\My-School
PS D:\My-School> Select-String .
>> -Path .\backend\cek-ganache.cjs, .\backend\cek-saldo.cjs
>> -Pattern "PRIVATE_KEY|privateKey[0x[a-fA-F0-9]{64}]"
>> -AllMatches
PS D:\My-School> |
```

Gambar 4.15 Pemeriksaan Git mengunjurkan file secret di-ignore dan tidak ter-trac

4.1.7 OWASP ZAP setelah Hardening

OWASP ZAP digunakan untuk membandingkan kondisi baseline dan setelah hardening. File report baseline dan after-hardening tersimpan dalam folder zap-reports. Hasil after-hardening yang dibahas menunjukkan empat alert tersisa: satu kategori Medium dan tiga Informational. Temuan yang tersisa berkaitan dengan CSP style-src unsafe-inline serta informasi seperti Suspicious Comments, Modern Web Application, dan Non-Storable Content. Tidak ditemukan FAIL

pada baseline automation yang dibahas sebelumnya; alert yang tersisa tetap dicatat sebagai pekerjaan lanjutan, bukan diabaikan.

```
PS D:\My-School\backend\blockchain> Get-ChildItem D:\My-School\zap-reports

Directory: D:\My-School\zap-reports

Mode                LastWriteTime         Length Name
----                -
-a-----         8/25/2026   5:04 AM           41077 zap-after-hardening.html
-a-----         8/25/2026   5:04 AM           11993 zap-after-hardening.json
-a-----         8/25/2026   4:54 AM           71213 zap-baseline-report.html
-a-----         8/25/2026   4:54 AM           24898 zap-baseline-report.json
-a-----         8/25/2026   5:03 AM             897 zap.yaml

PS D:\My-School\backend\blockchain> Get-Content D:\My-School\zap-reports\zap-after-hardening.json -Raw |
>> ConvertFrom-Json |
>> Select-Object -ExpandProperty site |
>> Select-Object -ExpandProperty alerts |
>> Group-Object riskdesc |
>> Select-Object Name,Count

Name                Count
----                -
Medium (High)              1
Informational (Medium)     3

PS D:\My-School\backend\blockchain>
```

Gambar 4.14 File report OWASP ZAP dari ringkasan jumlah aler setelah hardening

```
Windows PowerShell

Directory: D:\My-School\zap-reports

Mode                LastWriteTime         Length Name
----                -
-a-----         8/25/2026   5:04 AM           41077 zap-after-hardening.html
-a-----         8/25/2026   5:04 AM           11993 zap-after-hardening.json
-a-----         8/25/2026   4:54 AM           71213 zap-baseline-report.html
-a-----         8/25/2026   4:54 AM           24898 zap-baseline-report.json
-a-----         8/25/2026   5:03 AM             897 zap.yaml

PS D:\My-School\backend\blockchain> Get-Content D:\My-School\zap-reports\zap-after-hardening.json -Raw |
>> ConvertFrom-Json |
>> Select-Object -ExpandProperty site |
>> Select-Object -ExpandProperty alerts |
>> Group-Object riskdesc |
>> Select-Object Name,Count

Name                Count
----                -
Medium (High)              1
Informational (Medium)     3

PS D:\My-School\backend\blockchain> Get-Content D:\My-School\zap-reports\zap-after-hardening.json -Raw |
>> ConvertFrom-Json |
>> Select-Object -ExpandProperty site |
>> Select-Object -ExpandProperty alerts |
>> Select-Object name,riskdesc

name                riskdesc
----                -
CSP: style-src unsafe-inline      Medium (High)
Information Disclosure - Suspicious Comments Informational (Medium)
Modern Web Application            Informational (Medium)
Non-Storable Content              Informational (Medium)

PS D:\My-School\backend\blockchain> |
```

Gambar 4.15 Daftar alert OWASP ZAP yang masih tersisa setelah hardening

Prowler dan Scout Suite tidak dijalankan karena prototype belum berada pada akun AWS/GCP nyata. Oleh karena itu, laporan tidak mengklaim adanya hasil audit konfigurasi cloud dengan kedua tool tersebut. Pengujian yang tersedia berfokus pada container, jaringan lokal, aplikasi web, API, dan smart contract.

4.1.8 Ringkasan pengujian Web dan Infrastruktur

No	Pengujian	Hasil	Analisis
1	Akses SISWA ke update nilai	403 Forbidden	RBAC backend menolak role yang tidak berwenang.
2	STAF_TU + MFA ke update nilai	200 OK	Role berwenang dapat melakukan operasi setelah MFA.
3	TLS/HTTPS	Aktif	Akses eksternal melalui WAF HTTPS; sertifikat lokal self-signed.
4	Security headers	Aktif	CSP, HSTS, X-Frame-Options, nosniff, dan header lain terdeteksi.
5	SQL Injection	403 Forbidden	Diblokir ModSecurity/OWASP CRS.
6	XSS	403 Forbidden	Diblokir ModSecurity/OWASP CRS.
7	Path Traversal	403 Forbidden	Diblokir ModSecurity/OWASP CRS.
8	Rate limiting	429	Request berlebihan dibatasi.
9	Network segmentation	Berhasil	PostgreSQL/Vault hanya pada private_net.
10	Git secret hygiene	Berhasil	Secret files di-ignore dan tidak ter-track.
11	OWASP ZAP after-hardening	4 alert tersisa	1 Medium dan 3 Informational; perlu tindak lanjut.

Tabel 4.1 Ringkasan hasil pengujian web dan infrastruktur lokal

4.2 Hasil Audit Smart Contract dan Pengujian Integritas Dokumen

4.2.1 Hardhat Security Tests

Pengujian otomatis smart contract dijalankan menggunakan Hardhat. Total tujuh test case berhasil. Pengujian mencakup registrasi dokumen, verifikasi dokumen valid, penolakan hash berbeda, penolakan wallet tidak sah, penolakan duplicate verification code, penolakan duplicate document hash, serta pemeriksaan bahwa contract tidak memiliki fungsi payable atau alur Ether yang menambah attack surface reentrancy berbasis Ether.

```

PS D:\My-School> cd D:\My-School\backend\blockchain
PS D:\My-School\backend\blockchain> npx hardhat test

DocumentRegistry
  ✓ harus bisa mendaftarkan dokumen (1238ms)
  ✓ harus bisa memverifikasi dokumen yang valid
  ✓ harus menolak hash dokumen yang berbeda

DocumentRegistry - Security Tests
HASIL : wallet tidak sah DITOLAK
  ✓ TEST 16 - wallet tidak sah harus ditolak (41ms)
HASIL : duplicate verification code DITOLAK
  ✓ TEST 17A - verification code sama harus ditolak
HASIL : duplicate document hash DITOLAK
  ✓ TEST 17B - duplicate document hash harus ditolak
HASIL : tidak ditemukan fungsi payable
REENTRANCY : tidak ada transfer Ether/external callback
  ✓ TEST 18 - contract tidak memiliki attack surface reentrancy berbasis Ether

7 passing (1s)
PS D:\My-School\backend\blockchain> |

```

Gambar 4.16 Hasil Hardhat: 7 test case berhasil (7 passing)

4.2.2 Statis Analis Menggunakan Slither

Slither berhasil menghasilkan file slither-report.json dengan status success true dan error null. Analisis yang dibahas pada project mencakup penggunaan equality pada fungsi verifikasi hash, penggunaan timestamp sebagai metadata, serta rekomendasi agar owner dapat dipertimbangkan immutable. Temuan tersebut diperlakukan sebagai catatan peningkatan desain; tidak ada temuan critical/high yang dilaporkan pada hasil yang dibahas.

```

Windows PowerShell
>> -Pattern "PRIVATE_KEY|privateKey[0x[a-fA-F0-9]{64}" `
>> -AllMatches
PS D:\My-School> Get-Item D:\My-School\backend\blockchain\slither-report.json

Directory: D:\My-School\backend\blockchain

Mode                LastWriteTime         Length Name
----                -
-a-----      8/25/2026   4:44 AM           45497 slither-report.json

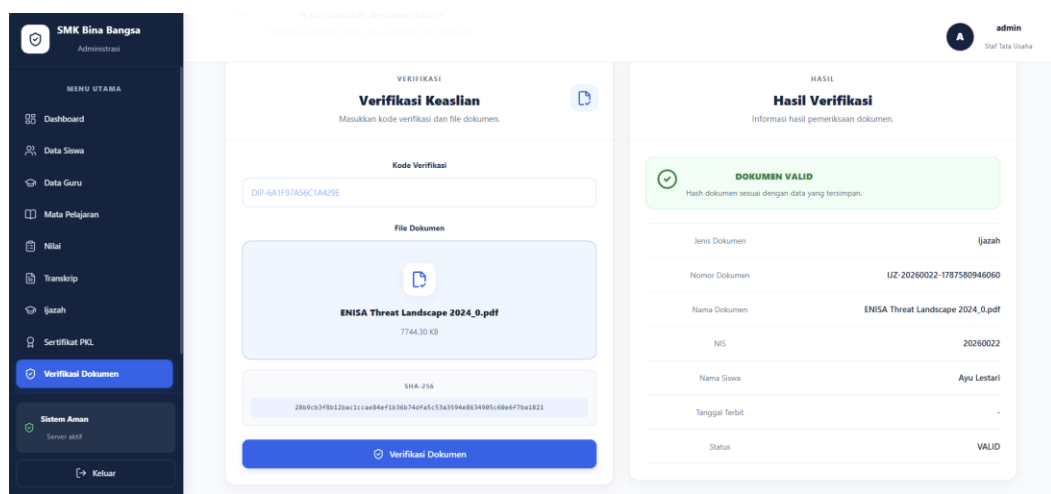
PS D:\My-School> Get-Content D:\My-School\backend\blockchain\slither-report.json -TotalCount 30
{
  "success": true,
  "error": null,
  "results": {
    "detectors": [
      {
        "elements": [
          {
            "type": "function",
            "name": "verifyDocument",
            "source_mapping": {
              "start": 1879,
              "length": 626,
              "filename_relative": "contracts/DocumentRegistry.sol",
              "filename_absolute": "/src/contracts/DocumentRegistry.sol",
              "filename_short": "contracts/DocumentRegistry.sol",
              "is_dependency": false,
              "lines": [
                83,
                84,
                85,
                86,
                87,
                88,
                89,
                90,
                91,

```

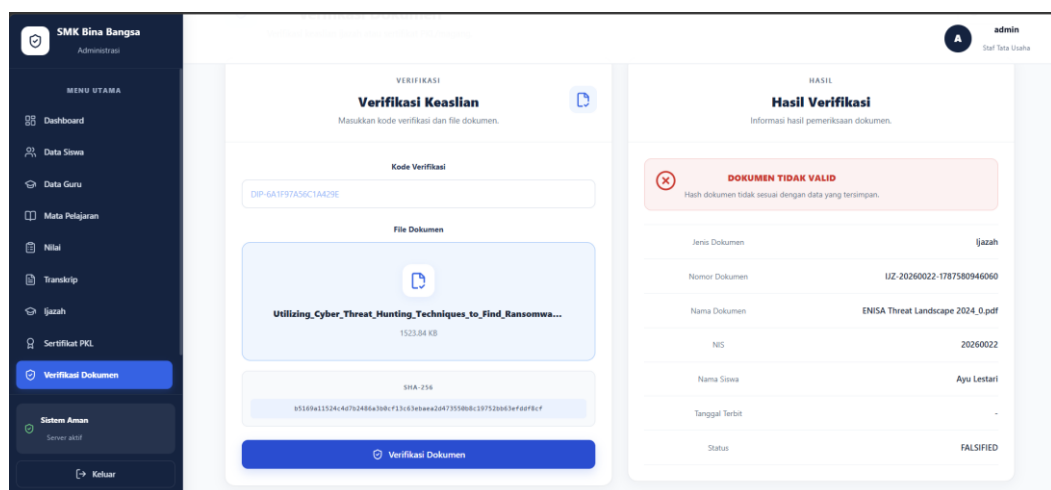
Gambar 4.17 Bukti report static analysis Slither pada DocumentRegistry

4.2.3 Pengujian Dokumen Hash Tempering

Pengujian integritas dilakukan dengan membandingkan dokumen yang sesuai dengan data blockchain dan dokumen yang isinya diubah. Dokumen valid menghasilkan hash yang cocok, sedangkan dokumen yang berubah menghasilkan hash berbeda dan status tidak valid. Mekanisme ini memenuhi tujuan utama blockchain layer, yaitu memberikan bukti integritas berdasarkan SHA-256 tanpa menyimpan file asli di ledger.



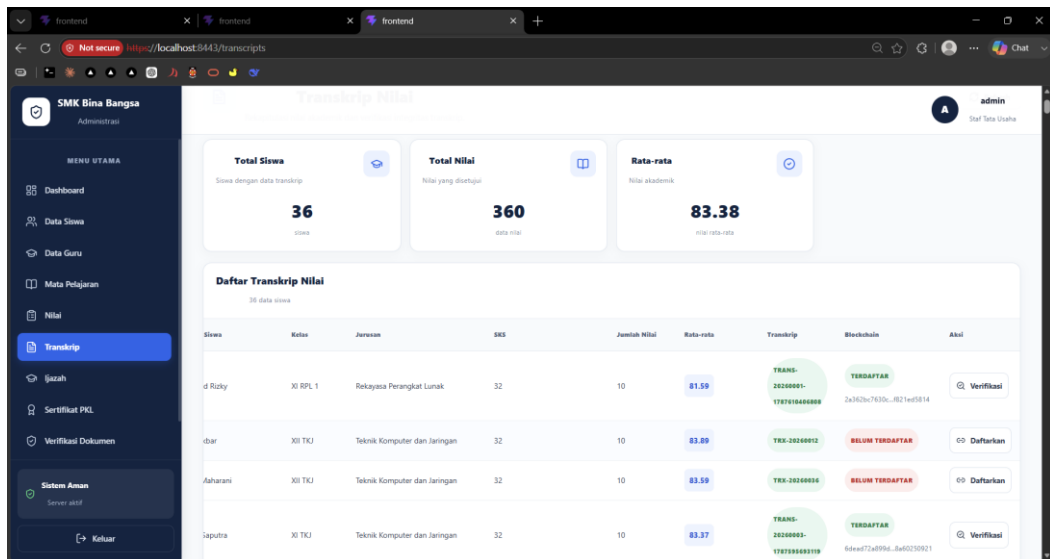
Gambar 4.18 Verifikasi dokumen dengan hash yang sesuai dinyatakan valid



Gambar 4.19 Verifikasi dokumen dengan hash berbeda dinyatakan tidak valid

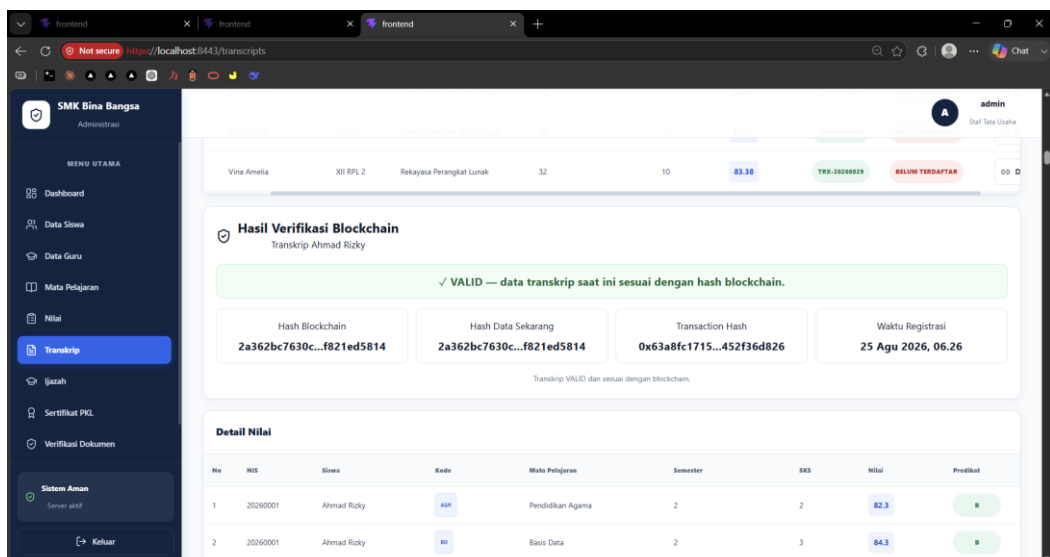
4.2.4 Blockchain Transcript

Transkrip dibentuk dari data nilai yang telah disetujui kemudian dihitung menjadi hash canonical. Hash tersebut diregistrasikan ke blockchain. Pada proses verifikasi, hash blockchain dibandingkan dengan hash data saat ini. Tampilan aplikasi menunjukkan status VALID ketika kedua nilai sesuai.



Siswa	Kelas	Jurusan	SKS	Jumlah Nilai	Rata-rata	Transkrip	Blockchain	Aksi
Ahmad Rizky	XII RPL 1	Rekayasa Perangkat Lunak	32	10	81.59	TRANS-20200001-1787010400008	TERDAFTAR	Verifikasi
Bar	XII TKJ	Teknik Komputer dan Jaringan	32	10	83.09	TRX-20200012	BELUM TERDAFTAR	Daftarkan
Asharani	XII TKJ	Teknik Komputer dan Jaringan	32	10	83.59	TRX-20200006	BELUM TERDAFTAR	Daftarkan
Iqbal	XII TKJ	Teknik Komputer dan Jaringan	32	10	83.37	TRANS-20200003-1787010400019	TERDAFTAR	Verifikasi

Gambar 4.20 Tampilan daftar transkrip dengan status registrasi/verifikasi blockchain

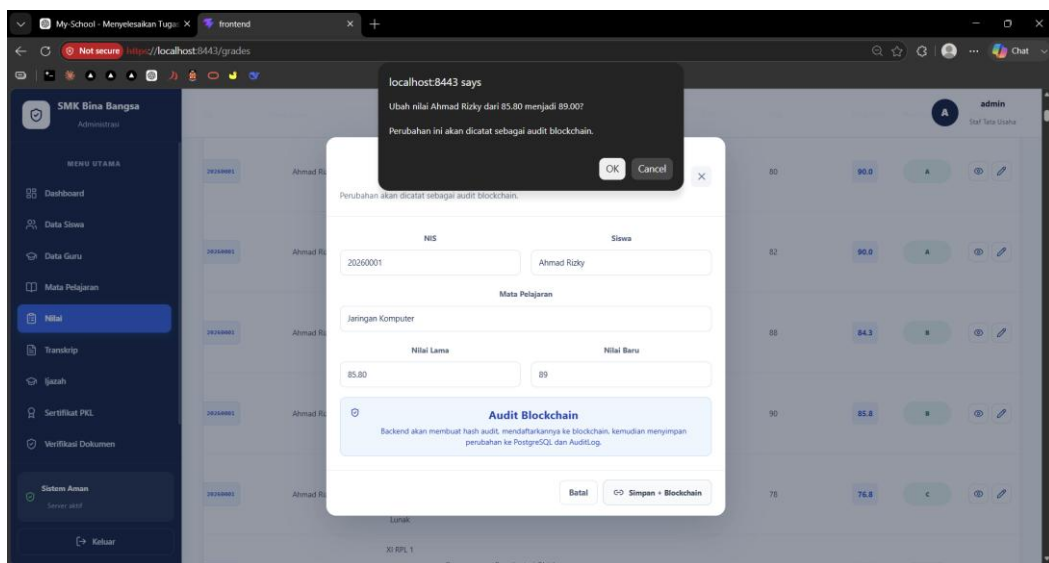


No	NIS	Siswa	Kode	Mata Pelajaran	Semester	SKS	Nilai	Profil
1	20200001	Ahmad Rizky	AGR	Pendidikan Agama	2	2	82.3	B
2	20200001	Ahmad Rizky	BP	Basis Data	2	3	84.3	B

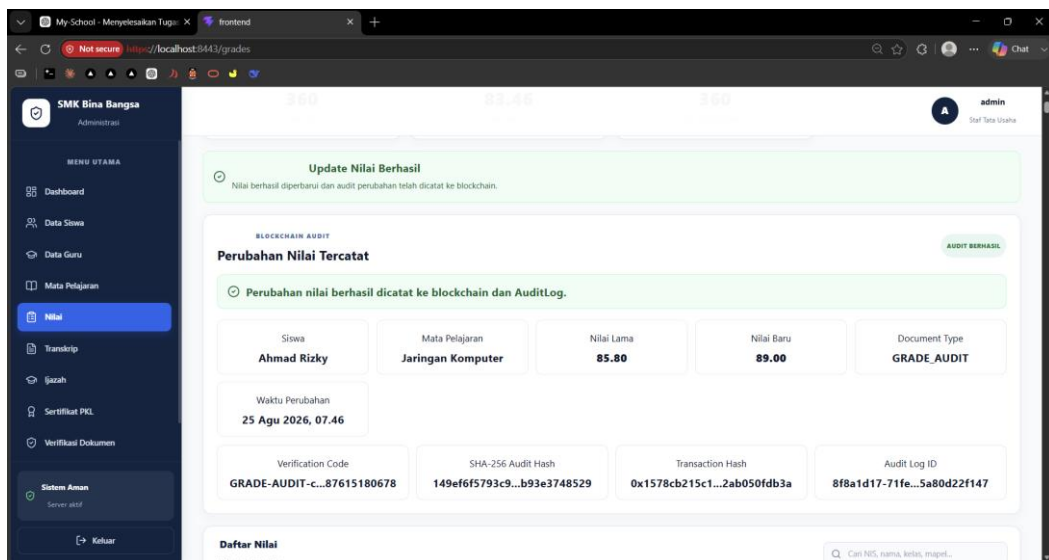
Gambar 4.21 Hasil verifikasi blockchain pada transkrip dinyatakan VALID

4.2.5 Grade Blockchain Audit

Perubahan nilai oleh role yang berwenang tidak hanya mengubah data aplikasi, tetapi juga menghasilkan audit hash dan transaksi blockchain. Bukti tampilan menunjukkan perubahan nilai disimpan bersama verification code, SHA-256 audit hash, transaction hash, dan audit log. Pengujian terminal pada STAF_TU menghasilkan HTTP 200 dan pesan bahwa nilai berhasil diperbarui serta audit perubahan telah dicatat ke blockchain.



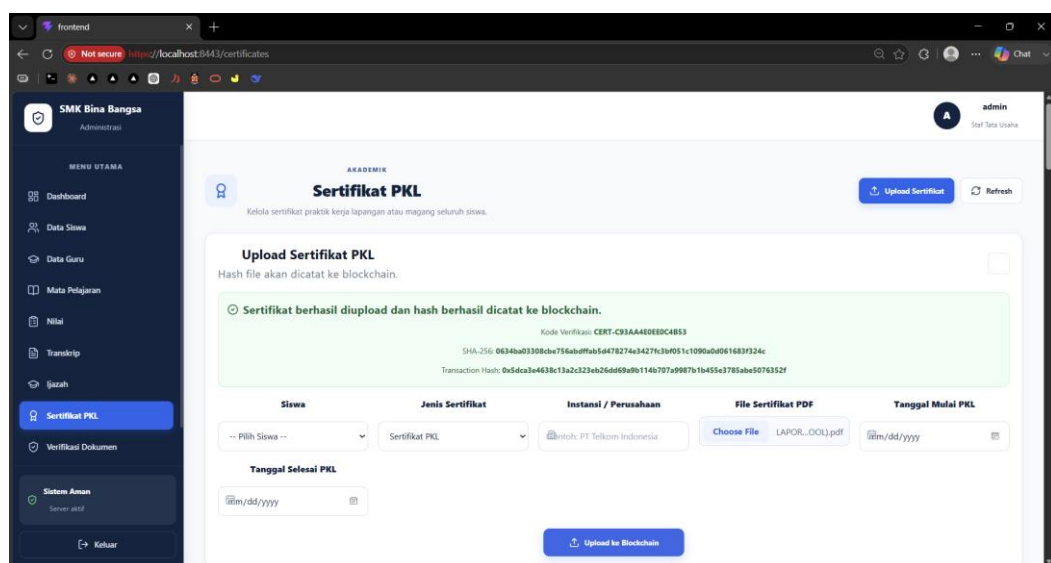
Gambar 4.22 Form perubahan nilai yang akan dicatat sebagai audit blockchain



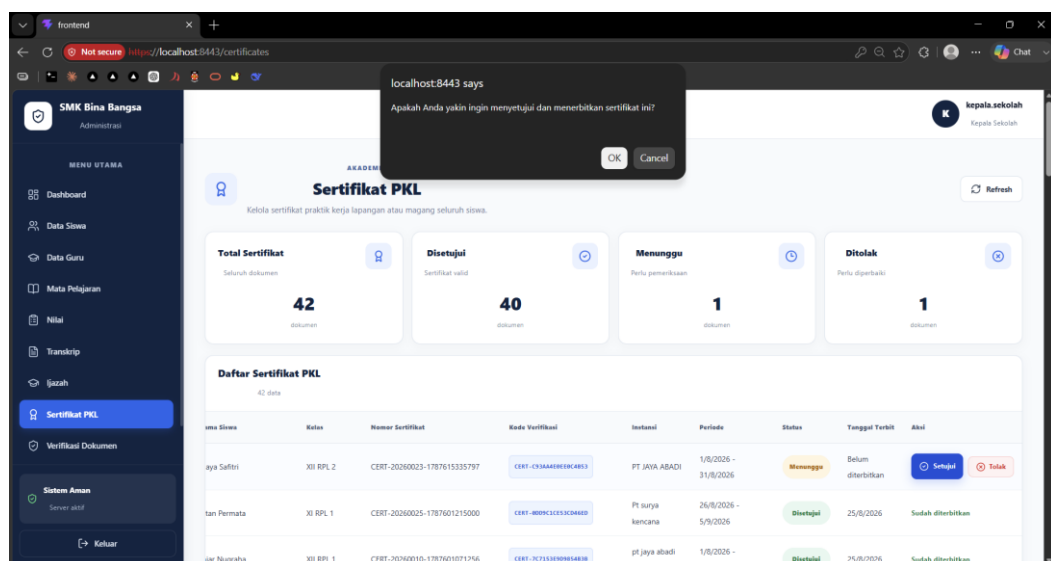
Gambar 4.23 Hasil perubahan nilai berhasil dan informasi `GRADE_AUDIT` tercatat

4.2.6 Dudi Digital Signature Dan Sertifikat Pkl

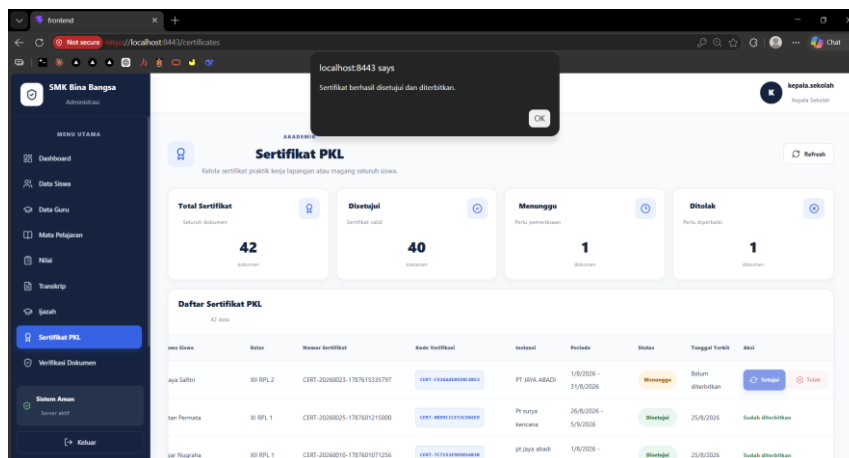
Sertifikat PKL dapat diunggah dan hash-nya dicatat ke blockchain. Pada prototype, proses tanda tangan digital DUDI menggunakan signer yang dikelola server untuk membuktikan alur kriptografi dan verifikasi. Implementasi ini belum sama dengan skenario produksi ketika DUDI menandatangani menggunakan wallet eksternal miliknya sendiri atau private key yang dikelola KMS/HSM.



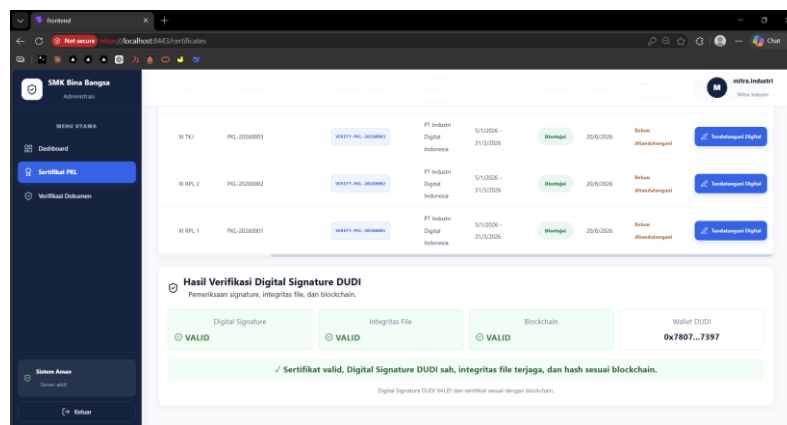
Gambar 4.24 Upload sertifikat PKL dan pencatatan hash ke blockchain



Gambar 4.25 Proses konfirmasi penandatanganan digital sertifikat oleh DUDI



Gambar 4.26 Notifikasi sertifikat berhasil ditandatangani



Gambar 4.27 Verifikasi digital signature DUDI, integritas file, dan blockchain dinyatakan VALID

4.2.7 Ringkasan Pengujian Blockchain Dan Smart Contract

No	Pengujian	Hasil
1	Koneksi backend ke Ganache	Berhasil, Chain ID 1337
2	Unauthorized wallet	Ditolak oleh kontrol owner
3	Duplicate verification code	Ditolak
4	Duplicate document hash	Ditolak
5	Hardhat security tests	7 passing
6	Slither static analysis	Report berhasil dibuat; temuan desain dicatat
7	Document hash tampering	Perubahan file menghasilkan status tidak valid
8	Blockchain transcript	Hash blockchain sesuai dengan data saat verifikasi
9	Grade blockchain audit	Perubahan nilai menghasilkan audit hash dan transaction hash
10	DUDI digital signature	Signature, integritas file, dan blockchain dapat diverifikasi pada prototype

Tabel 4.2 Ringkasan hasil audit smart contract dan pengujian integritas

BAB V

KESIMPULAN DAN REKOMENDASI

5.1 Kesimpulan

Berdasarkan perancangan, implementasi, dan pengujian yang dilakukan, prototype My-School telah menerapkan pendekatan keamanan berlapis yang sejalan dengan prinsip Zero Trust pada tingkat aplikasi dan container. Authentication, MFA, serta RBAC membatasi akses berdasarkan identitas dan kewenangan. Pengujian endpoint menunjukkan SISWA ditolak dengan 403 pada operasi perubahan nilai, sedangkan STAF_TU yang telah menyelesaikan MFA dapat menjalankan operasi yang sama dengan hasil 200 OK.

Pada lapisan perimeter dan komunikasi, TLS/HTTPS, security headers, ModSecurity dengan OWASP CRS, filtering, dan rate limiting telah diuji. Payload SQL Injection, XSS, dan path traversal menghasilkan 403 Forbidden. Segmentasi Docker memisahkan layanan publik dan privat sehingga PostgreSQL dan Vault tidak dipublikasikan langsung ke host. Secret aplikasi juga dipisahkan dari repository dan sebagian data sensitif, yaitu MFA secret, tersimpan menggunakan AES-256-GCM.

Pada lapisan blockchain, Ganache dan DocumentRegistry berhasil digunakan untuk registrasi dan verifikasi hash, transcript verification, grade audit, serta alur sertifikat PKL dengan digital signature DUDI pada prototype. Hardhat menghasilkan 7 passing dan Slither berhasil membuat report static analysis. Perubahan dokumen menghasilkan hash berbeda sehingga sistem dapat membedakan dokumen valid dan tidak valid.

Walaupun demikian, hasil ini merupakan bukti implementasi lokal dan tidak boleh disamakan dengan deployment cloud produksi. Komponen seperti AWS/GCP IAM, Cloud KMS/HSM, AWS Shield/Cloud Armor, object storage WORM, CloudTrail/GuardDuty, Prowler, dan Scout Suite belum diimplementasikan atau diuji pada cloud nyata.

5.2 Saran

- Melakukan deployment pada AWS atau GCP dengan pemisahan VPC/subnet nyata, security group/firewall, private database, dan load balancer/WAF terkelola.
- Menggunakan Cloud KMS/CloudHSM atau Vault production mode untuk pengelolaan private key dan data encryption key; hindari Vault dev mode pada produksi.
- Menerapkan enkripsi at rest pada seluruh storage/database, bukan hanya secret MFA.
- Mengganti sertifikat self-signed dengan sertifikat dari CA yang terpercaya dan menegakkan TLS 1.3 pada edge produksi.
- Menambahkan DDoS protection terkelola, centralized logging, alerting, CloudTrail/Cloud Audit Logs, GuardDuty/Security Command Center, serta pengujian Prowler/Scout Suite setelah cloud tersedia.
- Menggunakan wallet eksternal DUDI atau signing service berbasis KMS/HSM agar private key mitra tidak menjadi shared server-side signer.
- Menambahkan pengujian khusus front-running, nonce/replay, dan skenario smart contract yang lebih luas apabila jaringan dipindahkan ke testnet/consortium/production.
- Menjadwalkan backup otomatis, menyimpan backup pada lokasi terpisah, dan melakukan restore drill secara berkala.
- Menindaklanjuti alert OWASP ZAP yang masih tersisa, khususnya kebijakan CSP yang masih menggunakan unsafe-inline.